

安全控制等方面的内容。

(1) 登录访问控制策略。登录访问控制为系统访问提供了第一层访问控制，它控制哪些用户能够登录系统并获取资源，控制准许用户登录时间和具体工作站。用户的登录访问控制可分为三个步骤，分别是用户名的识别与验证、用户口令的识别与验证，以及用户账号的默认限制检查。三道关卡只要有一关未过，用户便不能登录系统。

(2) 操作权限控制策略。操作权限控制是针对可能出现的非法操作而采取的安全保护措施。用户和用户组被赋予一定的操作权限。系统管理员能够通过设置，指定用户和用户组可以访问系统中的哪些服务器和计算机，可以在服务器或计算机上操作哪些程序，访问哪些目录、子目录、文件和其他资源。系统管理员还可以根据访问权限将用户分为特殊用户、普通用户和审计用户，可以设定用户对能访问的文件、目录和设备执行的操作权限。

(3) 目录安全控制策略。系统应该允许管理员控制用户对目录、文件和设备的操作。目录安全允许用户在目录一级的操作对目录中的所有文件和子目录都有效。用户还可进一步自行设置对子目录和文件的权限。系统管理员应当为用户设置适当的操作权限，操作权限的有效组合可以让用户有效地完成工作，同时又能有效地控制用户对系统资源的访问。

(4) 属性安全控制策略。属性安全控制策略允许将设定的访问属性与服务器的文件、目录和设备联系起来。系统资源都应预先标出一组安全属性，用户对资源的操作权限对应一张访问控制表，属性安全控制级别高于用户操作权限设置级别。

(5) 服务器安全控制策略。系统允许在服务器控制台上执行一系列操作。用户通过控制台可以加载和卸载系统模块，可以安装和删除软件。系统应该提供服务器登录限制、非法访问者检测等功能。

9.4.2 访问控制模型

访问控制一般都是基于安全策略和安全模型的。访问控制模型是一种从访问控制的角度出发，描述系统安全，建立安全模型的方法。建立规范的访问控制模型，是实现严格访问控制策略所必需的。

1. Bell-LaPadula 模型

Bell-LaPadula (BLP) 模型是第一个正式的安全模型，该模型基于强制访问控制 (Mandatory Access Control, MAC) 系统，是典型的信息保密性多级安全模型，主要应用于军事系统中。在 BLP 模型中，数据和用户安全等级划分为公开、受限、秘密、机密和高密 5 个等级。

BLP 模型允许用户读取安全级别比它低的资源；相反地，写入对象的安全级别只能高于用户级别。BLP 模型基于两种规则来保障数据的机密度与敏感度，分别是上读和下写。上读是指主体不可读取安全级别高于它的数据，下写是指主体不可写入安全级别低于它的数据。例如，如果一个用户的安全级别为高密，想要访问安全级别为秘密的文件，他将能够成功读取该文件，但不能写入；而安全级别为秘密的用户访问安全级别为高密的文件，则会读取失败，但他能够写入。

2. Lattice 模型

在 Lattice 模型中，每个资源和用户都服从于一个安全类别。Lattice 模型通过划分安全边界